

Sub-processor Schedule — EHR / FHIR Health Records Provider

This schedule governs processing carried out in connection with the operator's designated **EHR / FHIR Health Records Provider** — the party providing patient-authorised access to electronic health records via SMART on FHIR. It is incorporated by reference into the Shyware Data Processing Agreement (`DATA_PROCESSING_AGREEMENT.tex`) and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-health>.

Configuration trigger: This schedule applies when the operator's `shyconfig` manifest sets `store.ehr_provider` (e.g. "epic") and `store.secret_categories` includes `health_record` or `health_record_era`. This schedule applies *in addition to* — not instead of — the Compute, Database, and Verification schedules. All four BAAs / DPAs must be in place before any PHI flows in production.

Role Definition

Field	Value
Sub-processor role	EHR / FHIR health records data source (patient-authorised)
Named provider (operator completes)	REQUIRED_OPERATOR_INPUT
FHIR version	REQUIRED_OPERATOR_INPUT
Contact for data protection	REQUIRED_OPERATOR_INPUT
Location	REQUIRED_OPERATOR_INPUT
Transfer mechanism (if outside EEA)	REQUIRED_OPERATOR_INPUT
HIPAA BAA status	REQUIRED_OPERATOR_INPUT

Role in the Data Flow

The EHR provider is a **data source**, not a downstream processor. The patient authorises access via SMART on FHIR OAuth. The keybox app fetches only the FHIR resource types the patient explicitly consented to (consent-scoped OAuth token), encrypts the payload client-side before transmission, and stores the sealed blob via the shystore two-list invariant. The EHR provider does not receive any shyware canonical-state data and does not process data on behalf of the operator after the OAuth handshake.

Notwithstanding the above, the EHR provider holds its own copy of the patient record and is independently subject to HIPAA and applicable health privacy law. This schedule governs the operator's obligations in relation to that access, not the provider's independent obligations as a covered entity.

Data Accessed

FHIR Resource Type	Content	Consent Required
Observation	Labs, vitals, blood pressure, weight, oxygen	Per-resource explicit consent
Condition	Diagnoses — current and historical	Per-resource explicit consent
MedicationRequest	Active and historical prescriptions	Per-resource explicit consent
AllergyIntolerance	Drug, food, and environmental allergies	Per-resource explicit consent
Procedure	Surgeries, treatments, interventions	Per-resource explicit consent
Immunization	Immunization history	Per-resource explicit consent
DocumentReference	Clinical notes and reports	Per-resource explicit consent

Access is scoped to consented resource types only. The SMART on FHIR OAuth scope is generated from the patient's per-resource-type consent selection in the keybox ConsentGate UI (Art. 9(2)(a) explicit consent recorded via `POST /api/store/consent` before redirect). Unconsented resource types are excluded from the OAuth scope request.

Special Category Obligations (Art. 9) — Health Data

Health records are special-category personal data under GDPR Art. 9(1). Processing requires an Art. 9(2) exemption. The intended basis for keybox EHR deployments is:

- **Art. 9(2)(a) — Explicit consent.** The patient provides freely given, specific, informed, and unambiguous consent to import and vault each FHIR resource type before the SMART on FHIR redirect. Consent is recorded as a sealed consent record in the shystore ledger. Withdrawal of consent triggers deletion of all associated health records and the consent record via the Art. 17 erasure path.
- Consent must be granular per resource type — a single blanket consent for `patient/*.read` is not sufficient for Art. 9(2)(a).
- The operator must maintain a record of each consent act (timestamp, scope, resource types, `consentId`) for accountability under Art. 5(2).

HIPAA Requirements (US Deployments)

If the deployment processes Protected Health Information (PHI) of US persons, HIPAA applies independently of GDPR. The operator must:

- Execute a signed BAA with the EHR provider (Epic and most covered entities provide standard BAAs; confirm scope covers SMART on FHIR access).
- Execute signed BAAs with all sub-processors that handle PHI: Compute provider (AWS — standard BAA available under AWS Customer Agreement; confirm covers EC2, KMS, S3 Object Lock); Database provider (CockroachDB HIPAA-eligible tier required); IDV provider (identity context only, no PHI payload; confirm BAA availability).
- Register a production FHIR client ID with each EHR provider and configure `VITE_FHIR_CLIENT_ID` in the CI/CD environment before production build. The `demo-client-id` fallback must not be used in production.
- Apply the minimum necessary standard: the consent gate scopes the OAuth token to consented resource types only — structural minimum-necessary enforcement.
- Maintain a breach notification procedure meeting the HIPAA 60-day notification obligation.
- Implement FHIR access token revocation in the erasure workflow: shyware canonical deletion does not automatically revoke provider-side authorisation. The operator must separately revoke the SMART on FHIR access token and delete the FHIR authorisation when the patient withdraws consent or exercises Art. 17 erasure.

Structural Constraints

- **Client-side sealing before storage:** FHIR payloads are encrypted by the keybox client using participant-derived keys (HKDF-SHA256) before any data reaches the shyshare canonical layer. The EHR provider and shyshare canonical infrastructure never hold plaintext health records simultaneously.
- **Consent-scoped OAuth token:** The SMART on FHIR access token is scoped to the exact resource types the patient consented to. The EHR provider enforces this scope at the FHIR API layer independently of the shyshare layer.
- **No cross-participant enumeration:** The shyshare API structurally rejects bulk health record enumeration (verified: `GET /api/store/secrets/all` returns 403). The EHR provider's own data is subject to its own access controls.
- **Art. 17 erasure path:** Canonical deletion of sealed health blobs is verified (EHR ERASURE section, `keybox.unit.mjs`). FHIR-side erasure requires separate FHIR token revocation by the operator.
- **Authenticator surface isolation:** The `authenticator.keybox.fyi` biometric re-derivation surface does not transmit or receive EHR payloads. It issues a session credential to the vault only.

HIPAA Technical Safeguards Mapping (45 CFR §164.312)

The 2025 HIPAA Security Rule NPRM (published January 6, 2025; final rule expected 2026) eliminates the addressable/required distinction and makes all specifications mandatory for every covered entity and business associate. The shystore structural layer satisfies or supports each requirement as follows:

Safeguard (45 CFR §164.312)	Shyware structural mechanism	Patent claim
Access controls — unique user ID	Each participant's L2 record = $H(\text{uid} \text{scopingId})$; scoped per submission, unlinkable across records. No two submissions for the same user share an on-chain identity.	Claim 25
Access controls — encryption/decryption	Payload sealed with AES-256-GCM before any network transmission; sealer key required for decryption; operator holds sealer key in AWS KMS (FIPS 140-3 L3).	Claims 28–30
Access controls — minimum necessary	Canonical state structurally excludes over-collection: no join key between L1 (payload commitment) and L2 (identity hash) is ever written. Non-composable reconcile API (Claim 56) returns only the requesting participant's own record.	Claims 1, 56, 59
Audit controls	Authority-action audit surface (Claim 60): every reconciling operation logged with timestamp, authority identity, action type, and canonical hash commitment. Signatures non-repudiable; no orphaned operations.	Claim 60
Integrity — no improper alteration	Count-match invariant $ L1(S) = L2(S) $ enforced atomically at the ABCI validation layer; HSM-attested period-close dual Merkle roots provide integrity proof (Claim 80); post-close modification rejected.	Claims 18, 73, 80

Safeguard (45 CFR §164.312)	Shyware structural mechanism	Patent claim
Person or entity authentication	Oracle-resistant identity binding (Claim 12): IDV provider cannot forge identity binding; per-submission keypair generated on device; biometric re-derivation for recovery without memorized secret.	Claims 12, 63
Transmission security	Write-only posture on hostile network (Claim 11): no receipt retained on device post-submission; all payloads sealed before transmission; TLS enforced at API layer.	Claims 11, 29

Note on the 2025/2026 HIPAA NPRM: The proposed rule would additionally require: (1) 72-hour breach notification to HHS (reduced from 60 days); (2) annual technology asset inventories; (3) vulnerability scanning every 6 months; (4) network segmentation. None of these are addressed by the shyware structural layer — they are operational obligations for the deploying operator. See Operator Obligations below.

Operator Obligations

- Register a production FHIR client ID and configure `VITE_FHIR_CLIENT_ID` before production build.
- Execute a signed DPA or BAA with each EHR provider and each sub-processor handling PHI before any health data flows.
- Deploy a counsel-reviewed Art. 9(2)(a) consent UI at `coach.keybox.fyi` before enabling EHR import in production.
- Maintain a consent log (timestamp, resource types, `consentId`, withdrawal timestamp if applicable) under Art. 30(1).
- Implement FHIR access token revocation in the erasure workflow.
- Notify Shyware of any change of EHR provider at least 30 days in advance.
- Complete a HIPAA risk analysis if the deployment involves US persons' PHI.

Audit and Retention

Health record consent logs must be retained for the period required by applicable law (minimum 6 years under HIPAA; Art. 5(1)(e) storage limitation under GDPR). Consent records stored in

the shystore ledger are subject to Art. 17 erasure on patient request, with the caveat that erasure of the consent record terminates the patient's ability to prove prior authorisation — document this tradeoff in the patient-facing consent UI.

This schedule is incorporated by reference into the Shyware Data Processing Agreement and is published at <https://shyware.fyi/legal/privacy/dpia/dpa/schedule-health>. Swap the named provider by updating `store.ehr_provider` in `shyconfig.json` and executing a new DPA / BAA with the replacement provider before transitioning.